SUP'COM · CYCLE D'INGÉNIEUR ICT · OPTION CYSED

DOSSIER DE CONCEPTION ET D'INGÉNIERIE DE SÉCURITÉ

DocTrace

Plateforme sécurisée de distribution et de traçabilité des documents confidentiels

Cahier des charges fonctionnel et technique
Spécification des exigences de sécurité
Évaluation des risques et des menaces

ÉQUIPE — TRINÔME 7

Achref Mansouri · **Ahmed Ben Ameur** · **Amin Ayed**

École Supérieure des Communications de Tunis

Réf. DOC-TRACE-DOS-01 · Novembre 2026

LECTURE DU RAPPORT

Sommaire

I. Cahier des charges — cadrage, solution et architecture 4

1. Contexte, problématique et objectifs 5
2. Acteurs, rôles et habilitations 5
3. Fonctionnalités et parcours métier 6
4. Marquage, stéganographie et empreintes 8
5. Scénarios d'utilisation 9
6. Architecture et conception UML 10
7. Interfaces, contraintes et hypothèses 16

II. Ingénierie des exigences de sécurité 17

8. Démarche et actifs à protéger 18
9. Scénarios d'abus et diagrammes 18
10. Catalogue des exigences de sécurité 22

III. Évaluation des risques et des menaces 28

11. Méthode et échelles de cotation 29
12. Registre détaillé des risques 29
13. Cartographie et risques résiduels 31
14. Glossaire et références 31

SYNTHÈSE DU PROJET

Une distribution contrôlée, une copie identifiable

DocTrace est une plateforme web destinée à distribuer des documents internes confidentiels, en contrôlant les droits d'accès et en associant chaque copie remise à une trace vérifiable.

01 — Contrôler

Gestion des rôles, ACL, niveaux d'habilitation et authentification multifacteur.

02 — Marquer

Marques PDF individualisées, stéganographie PNG applicable et empreintes SHA-256.

03 — Vérifier

Traçabilité des distributions et analyse prudente d'une copie suspecte.

Principe central

Une copie n'est émise qu'après validation des droits, de l'intégrité et des marquages requis, ainsi que l'enregistrement de sa distribution. Un échec bloque la remise.

Le projet couvre la conception métier, l'architecture Java/Jakarta EE, un catalogue de 21 exigences de sécurité et une évaluation structurée de sept risques, sur une échelle de vraisemblance et d'impact à quatre niveaux.

PARTIE I

Cahier des charges

Périmètre fonctionnel · mécanismes de marquage · architecture de référence

1 Contexte, problématique et objectifs

1.1 Présentation et positionnement

Les organisations diffusent des contrats, documents RH, procédures internes et rapports financiers à des collaborateurs autorisés. Une fois téléchargé, un fichier peut être redistribué hors du canal prévu. Les contrôles classiques limitent l'accès au moment de la consultation, mais ne suffisent pas à caractériser une copie retrouvée après une divulgation.

DocTrace associe la vérification des droits par le middleware, la génération d'une copie individualisée et la conservation d'un enregistrement de distribution. Lorsqu'un fichier suspect est soumis au module d'investigation, le système compare son empreinte et examine les marques encore vérifiables.

> **Question centrale**
> Comment distribuer les documents nécessaires aux collaborateurs tout en garantissant le contrôle des accès, l'identification technique des copies remises et la protection du dispositif de traçabilité ?

1.2 Objectifs opérationnels et de sécurité

Enjeu	Réponse de DocTrace	Objectif de conception
Diffusion non contrôlée	Copies individualisées et enregistrées	Chaque émission conforme est marquée et associée à une preuve de distribution.
Accès excessifs	RBAC, ACL et niveaux d'habilitation	Refuser les accès hors droits ; tests négatifs sur chaque endpoint documentaire.
Fuite découverte a posteriori	Analyse d'empreinte et extraction de marques	Retrouver la distribution technique lorsqu'une preuve subsiste.
Altération des traces	Enregistrements authentifiés et journal d'audit	Détecter la falsification des enregistrements de distribution.
Traitement hostile	Contrôles à l'import et limites de ressources	Rejeter ou isoler les contenus dangereux et prévenir les sorties incomplètes.

Indicateurs de conception issus du cahier des charges : 100 % des copies émises marquées et associées à une distribution ; révocation effective visée en moins de 60 secondes ; recherche d'une copie identique en moins de cinq secondes ; vérification quotidienne de l'intégrité de la chaîne d'audit ; absence visée de risque résiduel critique. Ces valeurs constituent des cibles de qualification du système.

Les objectifs de sécurité couvrent la confidentialité des documents et des clés, l'intégrité des originaux et des copies, ainsi que la disponibilité des services essentiels. Les trois procédés de traçabilité participent à l'analyse d'une copie ; ils ne démontrent pas, à eux seuls, l'identité de l'auteur humain d'une fuite.

2 Acteurs, rôles et habilitations

2.1 Acteurs du système

Acteur	Responsabilités et limites
ADMIN	Administre les comptes, rôles, catégories, habilitations et politiques ; consulte les historiques et les journaux autorisés. Ne bénéficie d'aucun accès implicite au contenu documentaire ni aux dossiers d'enquête.
PUBLISHER	Publie des documents, gère les ACL de ses documents et consulte les distributions liées à ses publications.
READER	Consulte les documents autorisés, télécharge des copies marquées et accède à son historique.
AUDITOR	Analyse les fichiers suspects, consulte les traces et les dossiers d'investigation pour lesquels il est habilité, produit les rapports ; ne modifie pas les originaux ni les traces.
Keycloak	Fournisseur d'identité OIDC ; authentification, MFA et émission des jetons.
ClamAV	Service antivirus associé à la procédure d'importation.
Acteurs adverses	Employé malveillant, compte compromis, utilisateur privilégié abusif ou attaquant externe.

2.2 Matrice des droits fonctionnels

Action	ADMIN	PUBLISHER	READER	AUDITOR
Gérer comptes et habilitations	Oui	—	—	—
Configurer catégories et niveaux	Oui	—	—	—
Gérer clés / politiques	Oui	—	—	—
Publier un document	—	Oui	—	—
Gérer les ACL de ses documents	—	Oui	—	—
Consulter le catalogue	Métadonnées autorisées	Selon droits	Selon droits	Métadonnées autorisées
Télécharger une copie	Non implicite	Selon droits	Selon droits	Non implicite
Consulter les historiques	Historiques autorisés	Ses documents	Son historique	Selon habilitation
Lancer une investigation	—	—	—	Selon habilitation
Exporter une investigation	—	—	—	Selon habilitation
Consulter le journal	Lecture autorisée	—	—	Lecture autorisée
Modifier les traces	Interdit	Interdit	Interdit	Interdit

Les décisions d'accès sont prises côté middleware sur la base du rôle, de l'objet demandé, des ACL en cours de validité et du niveau de confidentialité. La dissimulation d'un bouton dans React ne constitue pas une autorisation.

3 Fonctionnalités et parcours métier

3.1 Modules applicatifs

Module	Domaine	Fonctions prévues
M1	Identité et authentification	OIDC avec Keycloak, MFA, ouverture et clôture de session.
M2	Comptes et habilitations	Gestion des comptes, rôles et niveaux d'habilitation.
M3	Catalogue documentaire	Catégories, importation, recherche, ACL, expiration et archivage.
M4	Distribution marquée	Identifiant unique, watermark PDF, stéganographie PNG, SHA-256, enregistrement authentifié.
M5	Traçabilité et investigation	Recherche d'empreintes, extraction de marques, niveaux de confiance, rapport.
M6	Audit et administration	Journalisation, vérification des historiques, alertes et quotas.
M7	Client SPA/PWA	Interface React installable, états des opérations, coque statique hors connexion, FR/EN.

3.2 Référentiel des besoins fonctionnels

ID	Besoin fonctionnel	Module
BF-01	Connexion, déconnexion et profil	M1
BF-02	Gestion des comptes, rôles et habilitations	M2
BF-03	Catégories et niveaux de confidentialité	M3
BF-04	Importation et publication documentaire	M3
BF-05	Référence de version publiée et archivage	M3
BF-06	ACL, expiration et révocation	M3
BF-07	Consultation et recherche filtrées	M3
BF-08	Production et émission d'une copie marquée	M4
BF-09	Marque cachée PNG et vérification	M4
BF-10	Empreintes de l'original et de la copie	M4
BF-11	Analyse d'un fichier suspect	M5
BF-12	Consultation des distributions et journaux	M6
BF-13	Fonctionnement SPA/PWA et interface	M7

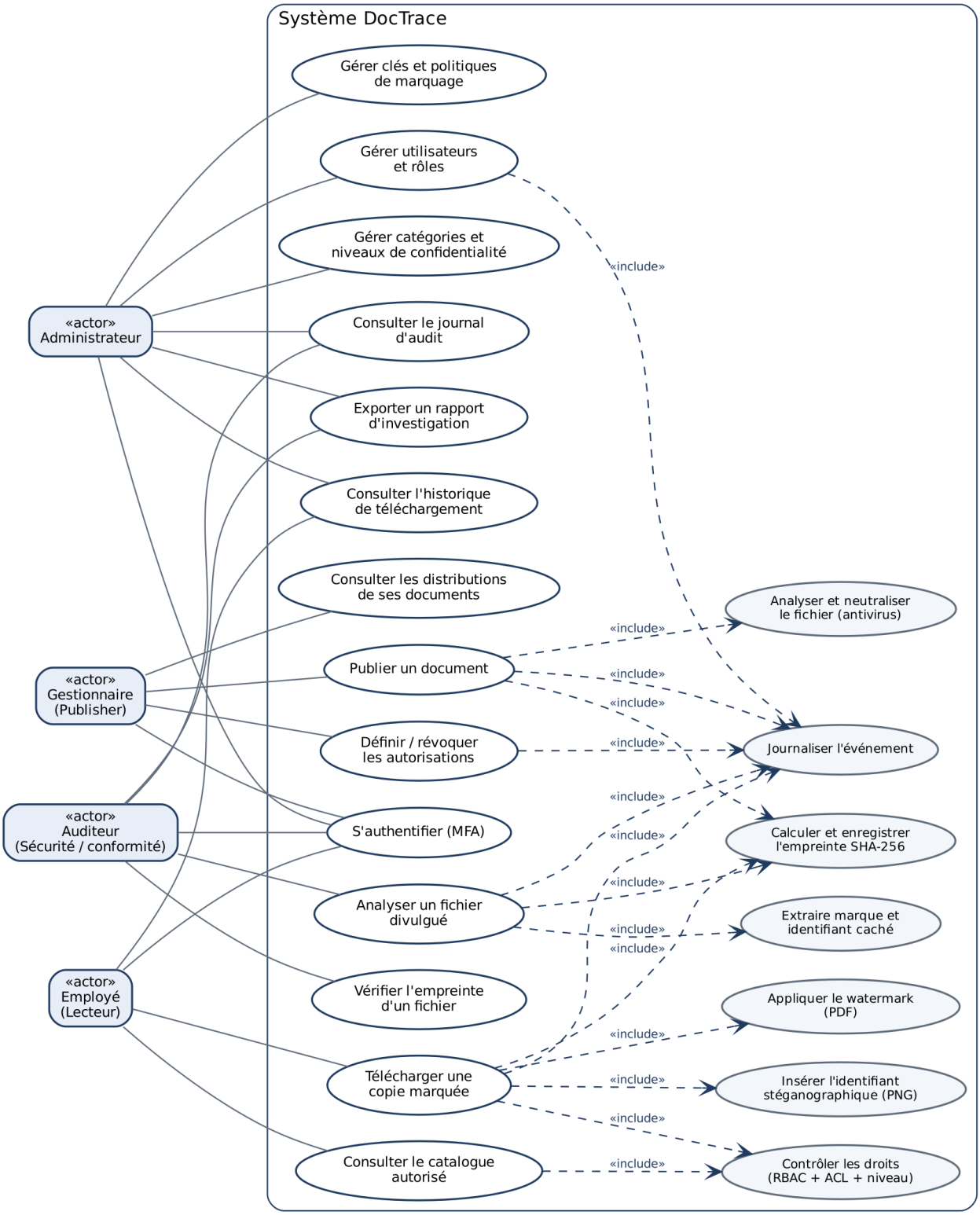


Figure 01 — Diagramme de cas d'utilisation : acteurs, interactions principales et relations entre fonctionnalités.

4 Marquage, stéganographie et empreintes

La traçabilité des copies repose sur trois mécanismes complémentaires. Leur comportement dépend du format, de l'intégrité du fichier suspect et des transformations qu'il a subies après distribution.

Technique	Support	Information associée	Limite principale
Watermarking	PDF	Destinataire, date et identifiant de distribution, en marques visible et discrète.	Peut être effacé par transformation ou ressaisie du contenu.
Stéganographie LSB	Images PNG éligibles	Charge AES-GCM contenant un identifiant de dossier et de distribution.	Fragile face à la recompression JPEG, au rognage et au redimensionnement.
Fingerprinting	Fichier original et copie finale	Empreinte SHA-256 des octets exacts.	Toute modification du fichier modifie l'empreinte.

4.1 Watermark PDF

- Marque visible : mention CONFIDENTIEL, destinataire, date et identifiant court sur les pages remises.
- Marque discrète : identifiant complet répété à des positions calculées selon une politique de marquage ; au moins trois emplacements lorsque le support le permet.
- Verification sur le document final : absence de marque obligatoire = remise interdite.
- Moteur : Apache PDFBox 3 ; génération asynchrone avec délai maximal de 30 secondes défini comme cible de conception.

4.2 Stéganographie dans les images PNG

Le mécanisme modifie les données des pixels d'une image PNG éligible ; il ne se limite pas aux métadonnées du PDF. L'image doit être décodable et présenter une capacité suffisante, avec une condition de dimensions d'au moins 128 × 128 pixels dans le procédé décrit.

Étape	Traitement technique
1	Extraire et contrôler les images PNG compatibles depuis le document ; vérifier dimensions et capacité.
2	Construire une charge contenant version du format, identifiant de dossier et identifiant de distribution (33 octets selon le modèle prévu).
3	Chiffrer et authentifier la charge avec AES-256-GCM, une clé dédiée et un nonce aléatoire de 12 octets ; tag de 16 octets.
4	Insérer le nonce dans des positions d'en-tête dérivées de la clé de stéganographie.
5	Dériver une permutation des positions LSB RGB via HKDF(clé, nonce), puis y insérer le corps chiffré.
6	Répéter les données pour permettre une extraction avec vote majoritaire, en vérifiant la capacité avant modification.
7	Réencoder en PNG sans perte et vérifier l'extraction authentifiée de la marque dans le document final.
Extraction	Récupérer le nonce, reconstruire la permutation, relire le corps, déchiffrer et vérifier le tag GCM. Une authentification échouée interdit l'attribution.

Le procédé initial prévoit un contrôle de qualité par PSNR (cible ≥ 40 dB). Lorsqu'aucune image éligible n'est disponible, le statut est « non applicable ». Un échec sur une image jugée éligible bloque la distribution.

4.3 Empreintes cryptographiques et enregistrement

- SHA-256 original : calcul à la publication, comparaison avant marquage à chaque distribution.
- SHA-256 copie : calcul sur les octets de la copie finale, associé au destinataire, à l'identifiant et à l'horodatage.
- Authentification : code HMAC-SHA-256 sur les champs de distribution, avec clé distincte des clés documentaires.
- Investigation : correspondance exacte du SHA-256 en priorité, puis recherche de marques si le fichier a été modifié.
- La reconnaissance perceptuelle d'images n'appartient pas au mécanisme de fingerprinting défini ici.

4.4 Chaîne de remise sécurisée

01 Autorisation de la requête

02 Déchiffrement et contrôle SHA-256 de l'original

03 Création du distributionId

04 Marquage visible / discret PDF

05 Stéganographie PNG lorsque applicable	**06** Vérification des marques et calcul SHA-256 final
07 HMAC et enregistrement de distribution	**08** Journalisation et émission HTTP sécurisée

Règle fail-closed

Aucune émission documentaire ne commence lorsqu'un contrôle préalable obligatoire échoue. Le statut « émise » constate le début du transfert côté serveur, sans garantir la réception intégrale par le navigateur.

5 Scénarios d'utilisation

S1 — Publication d'un document RH

Acteur : PUBLISHER · **Précondition :** Compte MFA, catégorie documentaire définie

1. Authentifier le responsable puis importer un document pour le catalogue.
2. Vérifier format, taille, antivirus et structure ; calculer l'empreinte et chiffrer l'original.
3. Attribuer classification et ACL aux destinataires pour une durée définie.
4. Consigner la publication dans le journal.

Résultat : Document original contrôlé, chiffré et publié avec permissions. BF-04, BF-06

S2 — Téléchargement d'une copie marquée

Acteur : READER · **Précondition :** ACL valide et habilitation suffisante

1. Afficher un catalogue filtré par les autorisations.
2. Vérifier jeton, rôle, ACL, classification et quotas à la demande de téléchargement.
3. Créer l'identifiant de distribution, appliquer watermark et marques cachées éligibles.
4. Contrôler la copie, calculer SHA-256, authentifier son enregistrement et transmettre en no-store.

Résultat : Copie individualisée et trace de distribution. BF-07, BF-08, BF-10

S3 — Investigation d'une copie divulguée

Acteur : AUDITOR · **Précondition :** Auditeur habilité et fichier suspect disponible

1. Déposer le fichier suspect et contrôler son admission.
2. Vérifier une éventuelle correspondance exacte SHA-256 avec une copie authentifiée.
3. En absence de correspondance, examiner watermark et stéganographie subsistante, puis authentifier les marques.
4. Émettre un résultat nuancé et un rapport d'investigation signé selon le procédé retenu, puis journaliser l'opération.

Résultat : Distribution retrouvée ou preuves insuffisantes, sans accusation automatique. BF-11

S4 — Tentatives adverses et contrôles défensifs

Acteur : Utilisateur malveillant · **Précondition :** Compte ou accès attaquant selon scénario

1. Modifier un identifiant dans une URL : autorisation réévaluée côté API.
2. Comparer les marques de plusieurs copies : le mécanisme ne remet aucune copie sans marquage conforme.
3. Saturer les traitements : refus contrôlé selon quotas et capacités de file.
4. Tenter de modifier des journaux par une API : aucune opération de modification autorisée.

Résultat : Actions interdites rejetées et événements sensibles journalisés. MU-01, MU-03, MU-04, MU-05

6 Architecture et conception UML

6.1 Architecture logique et technologies

Couche	Technologies	Responsabilité
Client	React, TypeScript, Vite, SPA/PWA	Interface installable ; cache statique uniquement.
Reverse proxy	Nginx, TLS, en-têtes de sécurité	Exposition HTTPS, durcissement, routage et limitations.
Middleware	Java 25, Jakarta EE 11, WildFly 42	APIs REST, validation, autorisation, règles métier, transactions.
Identité	Keycloak, OIDC, MFA	Authentification et délivrance des jetons.
Persistance	Jakarta Persistence, PostgreSQL, fichiers chiffrés	Métadonnées, ACL, historiques et originaux protégés.
Marquage	Apache PDFBox 3, Java ImageIO, JCA	Watermark, traitement des images, HMAC, SHA-256, AES-GCM.
Tâches	Jakarta Concurrency, file bornée	Traitements coûteux et contrôle de capacité.
Contrôle qualité	GitHub Actions, CodeQL, Dependency-Check, gitleaks, SBOM	Analyses de sécurité du code, dépendances et secrets.

6.2 Modèle de données

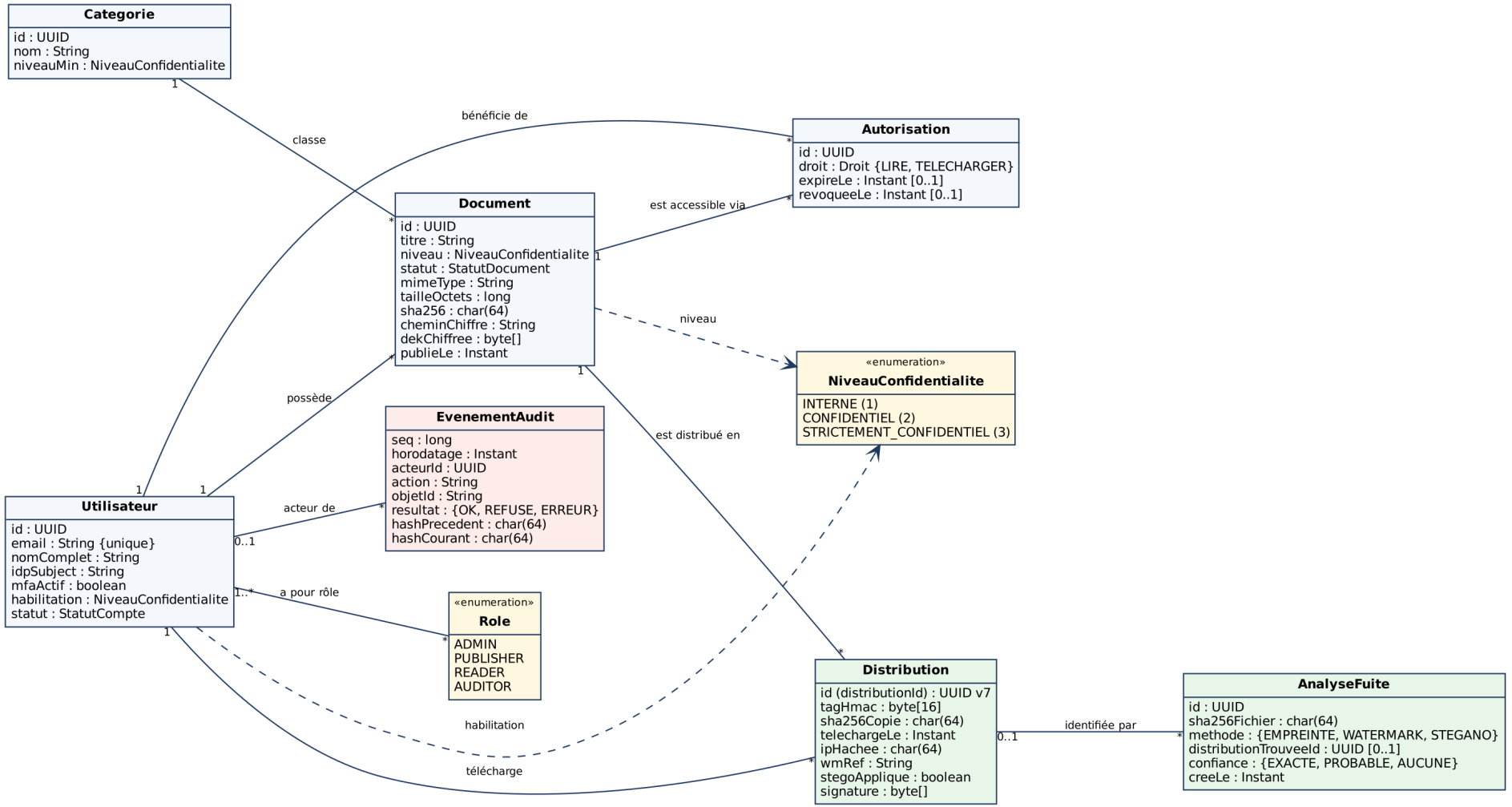


Figure 02 — Diagramme de classes : documents, habilitations, distributions, journaux et investigations.

6.3 Modèles dynamiques

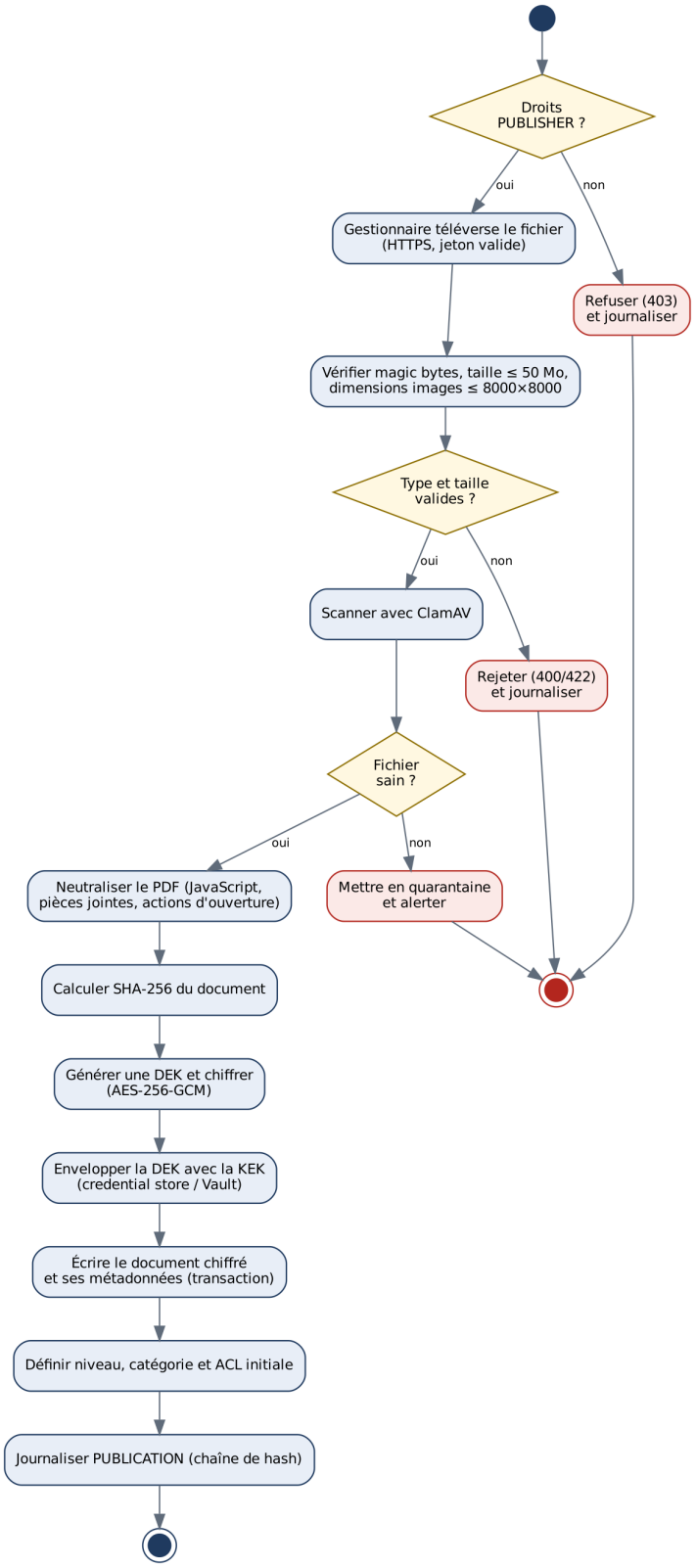


Figure 03 — Diagramme d'activité : contrôle et publication sécurisée.

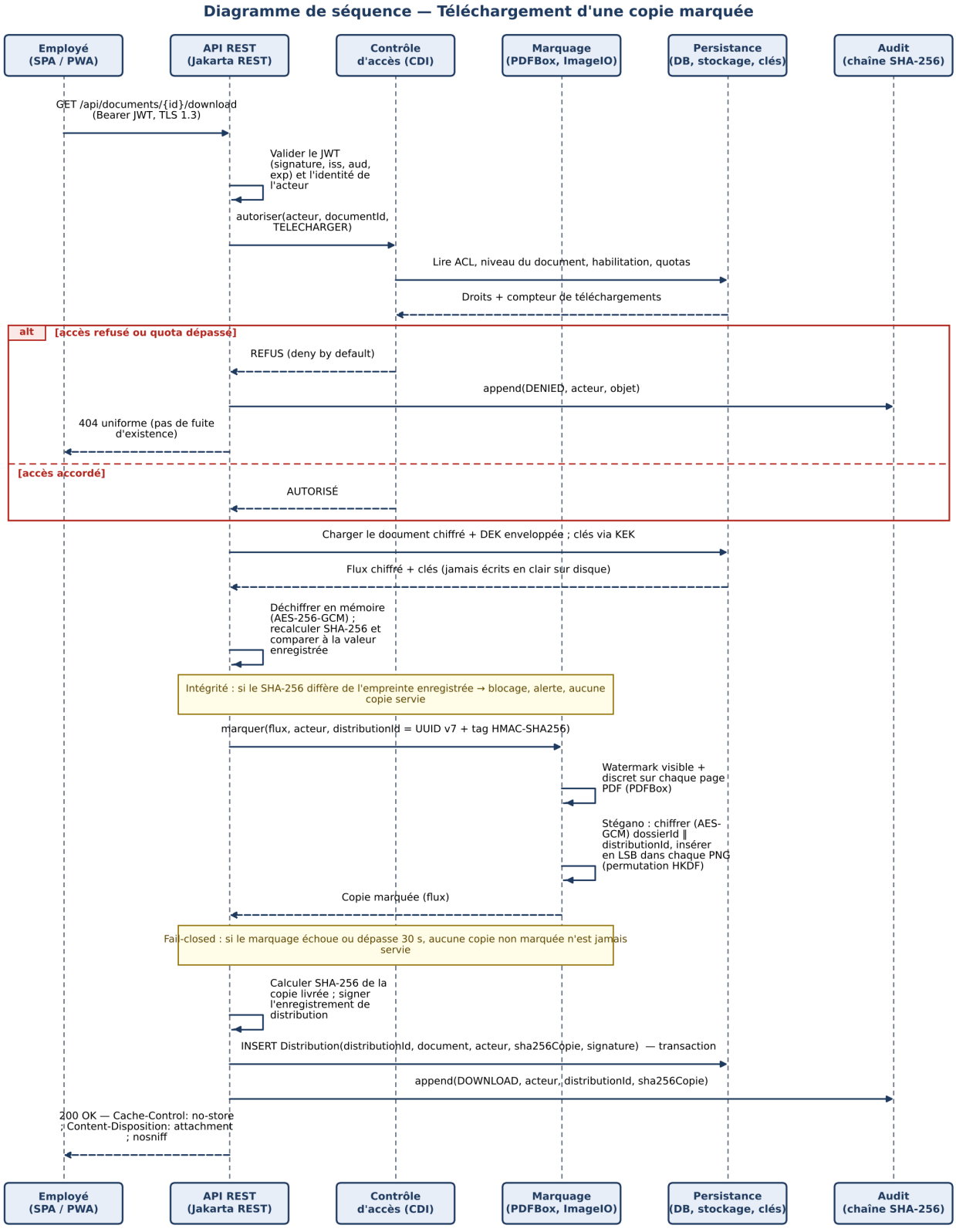


Figure 04 — Diagramme de séquence : production d'une copie marquée et émission sécurisée.

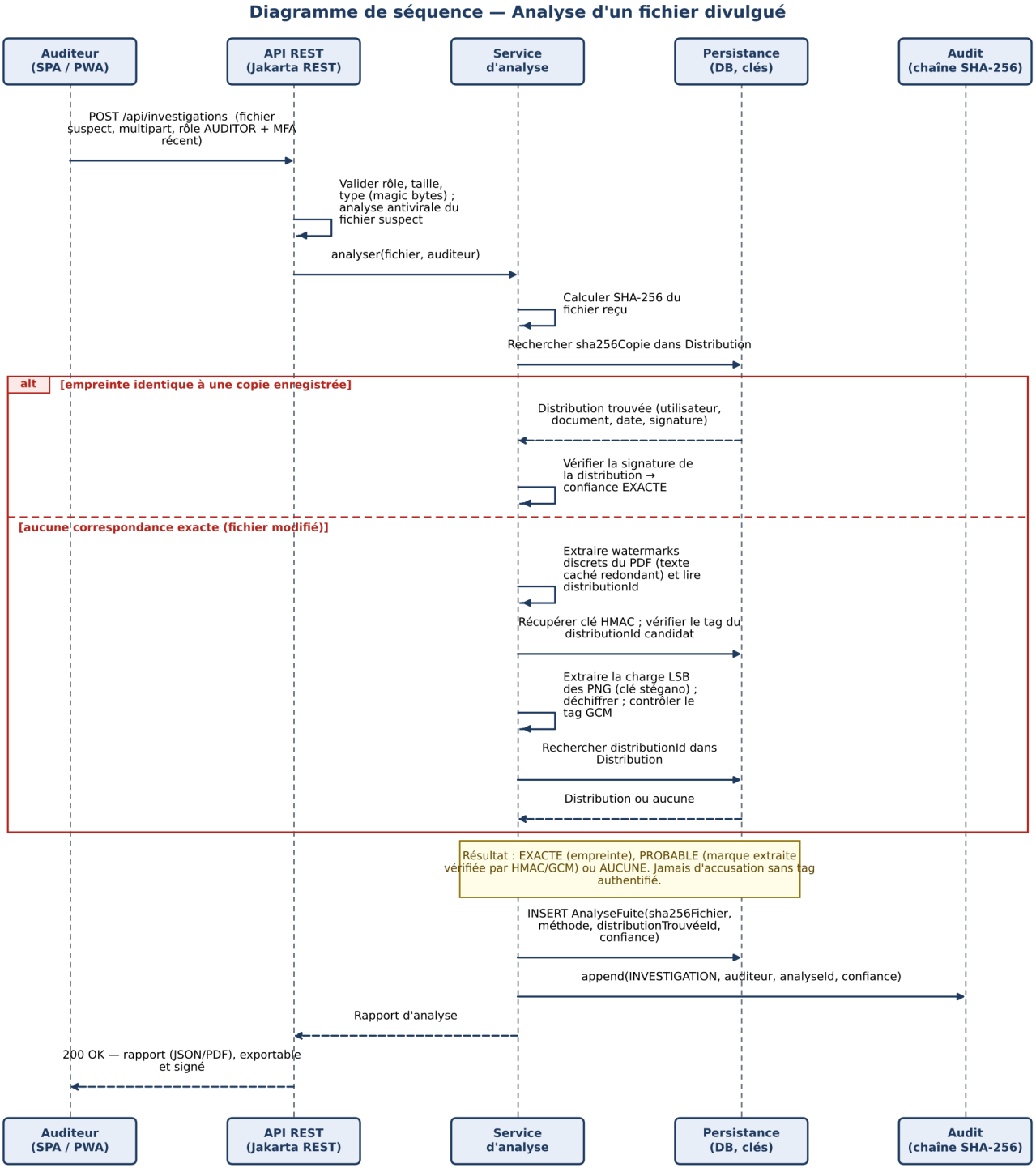


Figure 05 — Diagramme de séquence : vérification des empreintes et analyse d'une fuite.

6.4 Déploiement et zones de confiance

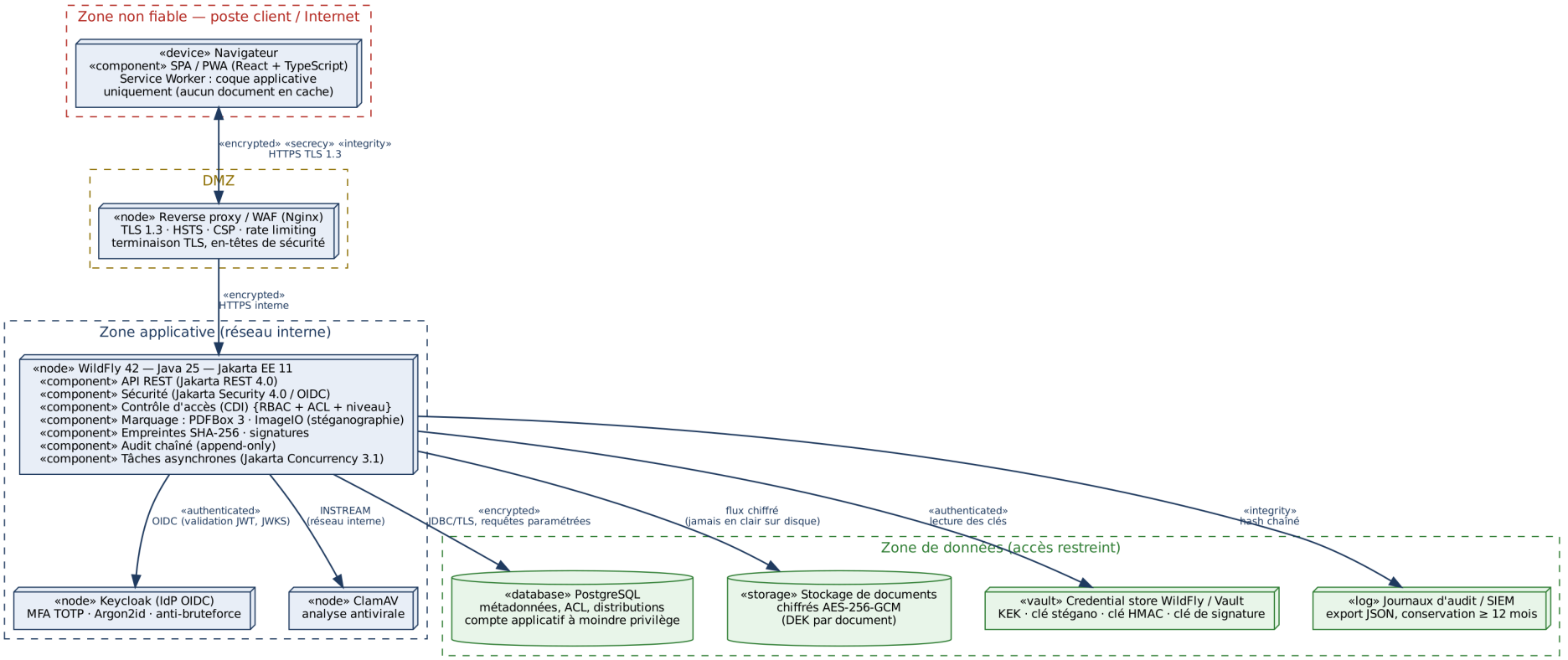


Figure 06 — Diagramme de déploiement UMLsec avec zones de confiance et canaux protégés.

Zone	Composants	Mesures structurantes
Z0 — externe	Navigateur et réseau de l'utilisateur	TLS, CSP et interdiction de conserver des documents dans le cache applicatif.
DMZ	Reverse proxy	Terminaison HTTPS, en-têtes de sécurité, contrôle de débit.
Zone applicative	WildFly, Keycloak, ClamAV	Services authentifiés, privilèges restreints, consoles de gestion non exposées.
Zone de données	PostgreSQL, stockage chiffré, clés, journaux	Séparation des clés, accès réseau restreints, intégrité des enregistrements.

Les stéréotypes UMLsec «encrypted», «secrecy», «integrity» et «authenticated» matérialisent respectivement la protection du canal, la confidentialité requise, l'intégrité des échanges et la vérification des identités aux frontières du système.

7 Interfaces, contraintes et hypothèses

7.1 Interfaces REST prévues

Méthode / chemin	Accès	Fonction
GET /api/me	Authentifié	Profil, rôles et habilitation
GET /api/users ; POST /api/users	ADMIN	Gestion des comptes
PATCH /api/users/{id}/roles	ADMIN	Gestion des rôles
GET /api/categories ; POST /api/categories	Selon action	Catégories et niveaux
GET /api/documents	Autorisé	Catalogue filtré et paginé
POST /api/documents	PUBLISHER	Publication
PUT /api/documents/{id}/acl	PUBLISHER propriétaire	Définition des autorisations
DELETE /api/documents/{id}/acl/{aclId}	PUBLISHER propriétaire	Révocation d'une autorisation
GET /api/documents/{id}/download	READER/PUBLISHER habilité	Copie marquée ; no-store
GET /api/documents/{id}/distributions	Rôle habilité	Distributions du document
GET /api/me/downloads	Authentifié	Historique personnel
GET /api/downloads	ADMIN/AUDITOR selon droits	Historique de distribution
POST /api/fingerprint/check	AUDITOR	Recherche par empreinte
POST /api/investigations	AUDITOR habilité	Analyse d'un fichier suspect
GET /api/investigations/{id}	AUDITOR habilité	Résultat ou rapport
GET /api/audit ; POST /api/audit/verify	ADMIN/AUDITOR autorisé	Consultation et vérification d'audit
GET /api/health/live ; /api/health/ready	Interne	Supervision

7.2 Contraintes et hypothèses de dimensionnement

- Architecture requise : SPA/PWA en frontend, Jakarta EE 11, WildFly 42 et Java 25 en middleware.
- Pour le marquage décrit, PDF et images PNG intégrées ; tout autre format admis au stockage nécessite un procédé de distribution défini avant émission marquée.
- Taille maximale documentaire définie : 50 Mo par version publiée.
- Ordre de grandeur envisagé : jusqu'à 200 utilisateurs, 5 000 documents et 10 000 téléchargements mensuels.
- Domaine HTTPS et service d'identité Keycloak disponibles.
- Information des utilisateurs quant aux mécanismes de marquage et de traçabilité ; politique de minimisation des données personnelles, conformément aux obligations applicables, notamment au cadre tunisien relatif à la protection des données personnelles.

7.3 Limites fonctionnelles

Le contrôle d'accès ne peut empêcher l'usage ultérieur d'une copie librement enregistrée après téléchargement. Les captures d'écran, la ressaisie, les recompressions destructrices ou les transformations lourdes peuvent diminuer l'efficacité des marques. La reconnaissance perceptuelle, la signature électronique à valeur légale, le chiffrement de bout en bout côté client, l'édition collaborative et la protection DDoS réseau volumétrique ne font pas partie des fonctions décrites.

La première organisation du catalogue ne prend pas en charge un historique de révisions d'un même document : une nouvelle édition est publiée comme un nouvel objet. La référence de version dans les preuves correspond au fichier publié et à son empreinte de référence.

PARTIE II

Exigences de sécurité

Actifs critiques · cas d'abus · spécification vérifiable des protections

8 Démarche et actifs à protéger

8.1 Approche d'ingénierie

La démarche de définition des exigences suit les activités SQUARE : définition des termes et objectifs de protection, identification des actifs, élaboration des artefacts de conception, analyse des risques, élicitation, classification, priorisation et inspection des exigences. Les cas d'abus servent à caractériser les menaces sur les fonctions métier et à rattacher les comportements défensifs attendus.

Étapes	Activité d'ingénierie
1–2	Définir les notions partagées, les actifs et les objectifs confidentialité, intégrité et disponibilité.
3–4	Établir l'architecture, les interactions, les scénarios d'abus et l'évaluation des risques.
5–6	Éliciter les protections à partir des usages, des interfaces exposées et des scénarios adverses.
7–8	Catégoriser et prioriser les exigences selon l'exposition et l'impact métier.
9	Inspecter leur précision, cohérence, traçabilité et possibilité de vérification.

8.2 Inventaire des actifs critiques

ID	Actif	CIA	Abus
A-01	Originaux chiffrés et métadonnées documentaires	C / I	MU-01, MU-02, MU-05
A-02	Copies distribuées et identifiants de remise	I / C	MU-04, MU-07
A-03	Clés cryptographiques et secrets techniques	C / I	MU-05, MU-06
A-04	Identités, jetons, rôles, habilitations et ACL	C / I	MU-01, MU-06, MU-08
A-05	Journaux, enregistrements de distribution et rapports	I / C	MU-05, MU-07
A-06	Moteurs de traitement et services d'analyse	A / I	MU-02, MU-03
A-07	Métadonnées personnelles de traçabilité	C / I	MU-05, MU-08

8.3 Terminologie des exigences

Terme	Interprétation dans DocTrace
Original	Octets du fichier publié, dont SHA-256 est calculé avant chiffrement.
Copie finale	Octets du document après application et vérification de tous les marquages obligatoires.
Émise	Transmission autorisée commencée côté serveur, sans préjuger de sa réception complète.
Droit documentaire	Autorisation côté middleware : rôle, objet, ACL active et habilitation.
Format admis	Format explicitement autorisé pour l'opération concernée ; stockage et distribution sont distincts.
Preuve d'investigation	Fichier suspect et résultats associés, protégés séparément des originaux publiés.

9 Scénarios d'abus et diagrammes de sécurité

Cas	Comportement adversarial	Fonctions	Contrôles associés
MU-01	Manipulation d'identifiants pour accéder au document d'autrui	BF-06, BF-07, BF-08	SR-03, SR-04
MU-02	Dépôt de fichiers dangereux ou excessivement coûteux à traiter	BF-04	SR-06, SR-07
MU-03	Saturation des imports, distributions ou investigations	BF-04, BF-08, BF-11	SR-07, SR-23
MU-04	Contournement du marquage ou remise d'une copie non conforme	BF-08, BF-10	SR-11, SR-12, SR-13, SR-15, SR-16

Cas	Comportement adversarial	Fonctions	Contrôles associés
MU-05	Abus de privilèges pour modifier droits, clés ou traces	BF-02, BF-11, BF-12	SR-03, SR-08, SR-16, SR-18, SR-24
MU-06	Usurpation d'identité et réutilisation d'un jeton	BF-01	SR-01, SR-02, SR-09, SR-22
MU-07	Fabrication de marques et fausse attribution	BF-08, BF-11	SR-12, SR-13, SR-15, SR-16, SR-17
MU-08	Exposition de données par scripts ou cache du navigateur	BF-13	SR-02, SR-10, SR-20, SR-21, SR-22

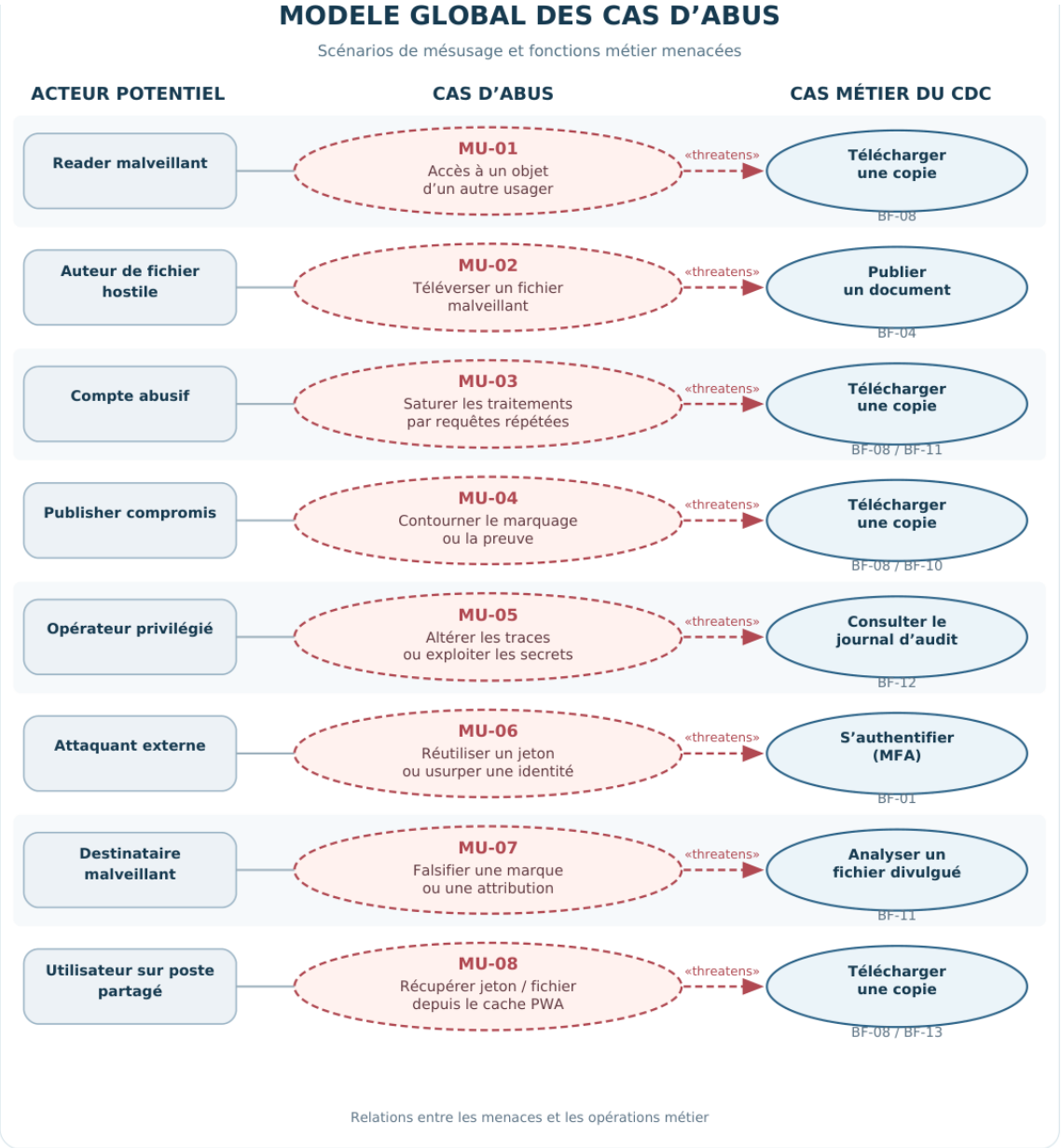


Figure SRE-01 — Cas d'abus globaux (MU-01 à MU-08) et fonctions métier menacées.

***Figure 07** — Diagramme des cas d'abus : acteurs adverses, scénarios MU et fonctionnalités menacées.*

La relation « threatens » matérialise une menace sur une opération métier ; « mitigates » désigne le comportement de sécurité destiné à l'atténuer. Les identifiants SR renvoient aux exigences du catalogue.

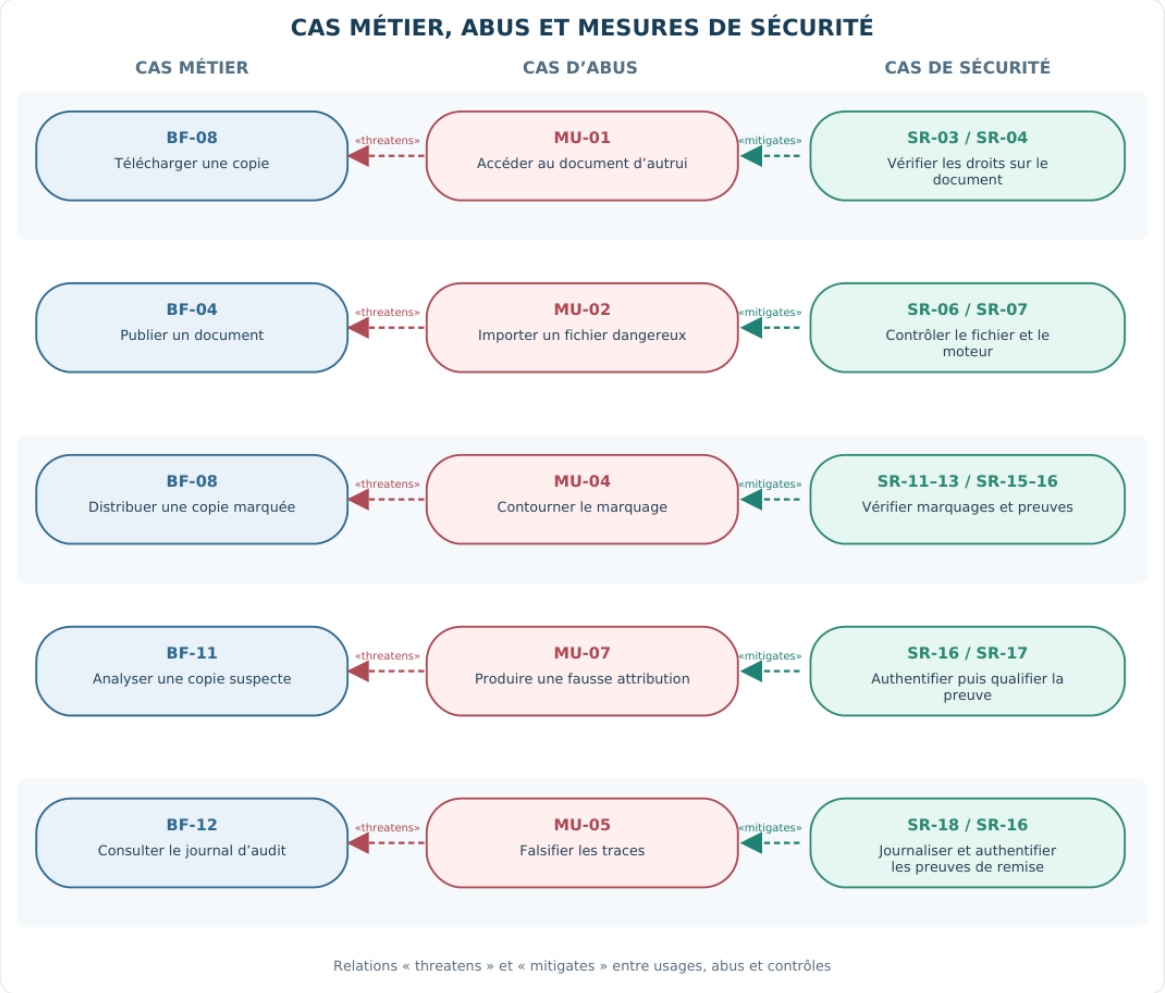


Figure SRE-02 — Cinq chaînes représentatives de protection ; les autres cas sont reliés dans le tableau MU.

***Figure 08** — Cas métier, comportements abusifs et réponses de sécurité («threatens» / «mitigates»).*

10 Catalogue des exigences de sécurité

Les exigences ci-dessous définissent les protections à appliquer par le système et leurs conditions de vérification. Les identifiants SR sont conservés pour assurer la traçabilité avec les scénarios de mésusage et les risques.

Identité et autorisations

SR-01 Authentification forte et validation des jetons

Critique · C/I

Exigence. Toute API nécessitant une identité doit accepter uniquement un jeton d'accès émis par le realm Keycloak DocTrace et destiné à l'API DocTrace ; elle doit vérifier la signature avec une clé de confiance, l'algorithme autorisé, l'émetteur (iss), l'audience (aud), l'expiration (exp) et la date de validité (nbf lorsqu'elle existe). Toute connexion interactive doit être réalisée avec MFA. La modification des rôles ou habilitations, la gestion des clés et l'ouverture ou l'export d'une investigation doivent exiger une preuve vérifiable de MFA datant de cinq minutes au plus.

Justification. Empêcher l'usurpation d'identité, l'acceptation de jetons destinés à un autre service et l'exécution d'opérations critiques avec une authentification insuffisante.

Critère de vérification. Présenter des jetons à signature incorrecte, issu d'un autre realm, portant une autre audience, expirés ou non encore valables : chaque requête protégée est refusée. Pour les opérations sensibles, tester une authentification MFA de quatre puis six minutes : seule la première satisfait la condition de fraîcheur, sous réserve des permissions.

Fonctions BF-01, BF-02, BF-11 Scénarios d'abus MU-06

SR-02 Sécurisation de la connexion SPA et des sessions

Élevée · C

Exigence. La SPA React doit utiliser OpenID Connect Authorization Code avec PKCE S256 auprès de Keycloak, sous un client public sans secret intégré au frontend. Les jetons d'accès et de rafraîchissement ne doivent pas être persistés dans localStorage, sessionStorage, IndexedDB ou Cache Storage. Les jetons doivent avoir une échéance, et les sessions doivent être clôturées à l'expiration de leur durée maximale, après la période d'inactivité configurée et à la déconnexion. La déconnexion doit supprimer les jetons détenus par la SPA et terminer la session Keycloak. Les jetons JWT autonomes non révoqués restent soumis à leur échéance.

Justification. Réduire le risque d'interception du code d'autorisation, d'exposition de secrets dans le frontend et de réutilisation des sessions.

Critère de vérification. Vérifier PKCE S256 et le refus d'un code_verifier incorrect ; contrôler l'absence de secret client dans les ressources React et l'absence de jetons dans les stockages persistants. Vérifier l'expiration d'un jeton et d'une session selon les durées configurées, la clôture de la session Keycloak et le comportement de l'API face à un JWT émis avant la déconnexion.

Fonctions BF-01, BF-13 Scénarios d'abus MU-06, MU-08

SR-03 Séparation des rôles et protection des investigations

Critique · C/I

Exigence. Le middleware doit appliquer la matrice des permissions de la section 2.2 aux rôles ADMIN, PUBLISHER, READER et AUDITOR, indépendamment des restrictions de l'interface. ADMIN ne reçoit aucun droit implicite de lecture du contenu documentaire. Les fonctions d'analyse, les dossiers, les preuves déposées et les exports d'investigation doivent être accessibles uniquement à un AUDITOR explicitement habilité sur la ressource concernée ; aucun AUDITOR ne doit pouvoir modifier les originaux ni les traces d'audit. Les droits non explicitement accordés doivent être refusés.

Justification. Empêcher l'élévation de privilèges, l'accès transversal aux enquêtes et la confusion entre administration, publication et audit.

Critère de vérification. Exécuter une matrice d'essais API par rôle et par ressource, dont ADMIN→lecture document, READER→investigation, PUBLISHER→export d'enquête, AUDITOR→altération d'original ou journal et AUDITOR non habilité→dossier d'un tiers ; vérifier les refus et la journalisation des accès sensibles.

Fonctions BF-02, BF-03, BF-11, BF-12 Scénarios d'abus MU-01, MU-05, MU-07

SR-04 Autorisation au niveau des documents

Critique · C

Exigence. Avant toute consultation de métadonnées, recherche, accès à une version ou émission de copie, l'API doit décider l'autorisation pour l'utilisateur authentifié et le document demandé à partir de la matrice des rôles, des droits du propriétaire selon le périmètre défini au cahier des charges, des ACL actives et non révoquées et du niveau d'habilitation. Les résultats de recherche et les métadonnées doivent être filtrés selon la même décision. Un identifiant de document, une URL ou une identité déclarée par le client ne confère aucun droit.

Justification. Prévenir BOLA/IDOR, la fuite de métadonnées et le contournement des règles d'accès par manipulation d'identifiants.

Critère de vérification. Tester un document autorisé puis un autre document avec identifiant substitué ; répéter avec ACL expirée, permission révoquée et habilitation insuffisante ; vérifier le refus côté API et l'absence de document ou métadonnée dans les résultats de recherche.

Fonctions BF-05, BF-06, BF-07, BF-08 Scénarios d'abus MU-01

Contrôle des fichiers

SR-06 Contrôle et admission des fichiers importés

Critique · I/A

Exigence. Chaque opération d'import doit accepter uniquement les formats autorisés pour sa fonction et vérifier la taille, le type réel et la structure du fichier avant sa prise en charge. Pour les versions publiées au catalogue, la taille ne doit pas dépasser 50 Mo et une analyse antivirus favorable doit précéder la publication. Tout fichier non conforme, détecté comme malveillant, non analysable ou soumis pendant une indisponibilité de l'antivirus doit rester inaccessible et ne pas être publié. Un fichier admis au stockage ne peut être distribué avec marquage que si un procédé de marquage est défini pour son format.

Justification. Empêcher l'introduction de contenus hostiles et éviter d'assimiler « fichier stockable » à « fichier distribuable ».

Critère de vérification. Tester un fichier conforme, un format interdit, un fichier déguisé, un fichier corrompu, un fichier dépassant 50 Mo, le fichier de test EICAR et une indisponibilité de l'antivirus. Aucune entrée non conforme ne doit atteindre l'état « publiée ». Vérifier que les formats sans procédé de marquage pris en charge sont refusés à l'étape de distribution.

Fonctions BF-04, BF-11 Scénarios d'abus MU-02

SR-07 Sécurisation du traitement des fichiers

Critique · I/A

Exigence. Les opérations d'analyse, de transformation et de marquage doivent appliquer aux fichiers les contrôles correspondant à leur format : validation structurelle, rejet des fonctions actives interdites et contrôle des volumes décodés lorsque nécessaire. Chaque tâche doit être exécutée avec des limites configurées de mémoire et de durée ; leur dépassement doit interrompre le traitement. Les fichiers temporaires doivent rester inaccessibles aux utilisateurs, et aucun fichier incomplet ou non vérifié ne doit être publié ou préparé pour distribution.

Justification. Limiter l'exploitation des parseurs et décodeurs, les décompressions abusives et les résultats incohérents.

Critère de vérification. Soumettre des fichiers malformés, des PDF comportant des fonctions interdites et des contenus dépassant volontairement les limites de traitement configurées. Vérifier l'arrêt contrôlé, l'isolation ou la suppression des fichiers temporaires et l'absence de résultat partiel accessible.

Fonctions BF-04, BF-08, BF-11 Scénarios d'abus MU-02, MU-03

Confidentialité et cryptographie

SR-08 Chiffrement des originaux et séparation des clés

Critique · C/I

Exigence. Chaque version originale doit être chiffrée au repos avec AES-256-GCM avant son stockage définitif. Un nonce de 96 bits ne doit jamais être réutilisé avec une même clé et le tag GCM de 128 bits doit être vérifié avant toute utilisation du contenu déchiffré. Les clés de chiffrement doivent être conservées hors du stockage documentaire, accessibles uniquement à l'identité technique autorisée et utilisables pour restaurer les versions sauvegardées.

Justification. Rendre inexploitable une copie brute du stockage sans accès aux clés, et détecter les altérations du chiffré.

Critère de vérification. Lire le stockage sans clé, tenter un déchiffrement sans autorisation et modifier un octet du chiffré : le contenu n'est pas révélé et l'altération est rejetée. Vérifier séparément la configuration du gestionnaire de clés et l'unicité des nonces sur un échantillon de chiffrement.

Fonctions BF-04, BF-05, BF-08 Scénarios d'abus MU-05

SR-09 Protection des communications sensibles

Élevée · C/I

Exigence. Les interfaces exposées transportant des identifiants, jetons, documents ou métadonnées sensibles doivent imposer HTTPS avec TLS 1.3 et certificat vérifiable. Aucun identifiant ni document ne doit être reçu ou émis via HTTP non chiffré. Les connexions entre le middleware et les composants internes véhiculant des données sensibles doivent employer un canal authentifié et chiffré, selon la configuration de déploiement approuvée.

Justification. Empêcher l'interception et l'altération des données en transit, y compris entre composants internes.

Critère de vérification. Tenter des requêtes HTTP vers l'API et des connexions TLS à certificat invalide ; contrôler qu'aucune donnée sensible n'est transmise. Vérifier les sessions TLS des flux navigateur–Keycloak, navigateur–API, API–base et API– services de clés.

Fonctions BF-01, BF-08, BF-11 Scénarios d'abus MU-06

SR-10 Minimisation et conservation des données de traçabilité

Élevée · C

Exigence. Les journaux techniques, historiques de distribution et rapports d'investigation doivent conserver uniquement les informations nécessaires à leur finalité. Les journaux techniques ne doivent contenir ni mots de passe, ni jetons, ni clés cryptographiques, ni contenu documentaire intégral. Les éléments probants nécessaires aux investigations doivent être protégés par les autorisations définies en SR-03. Chaque catégorie de données de traçabilité doit respecter une durée de conservation définie dans la politique du système ; à son terme, les données doivent être supprimées, sauf obligation de conservation applicable.

Justification. Limiter les fuites secondaires et la conservation excessive de données personnelles ou confidentielles.

Critère de vérification. Inspecter les journaux générés après connexion, distribution, refus et investigation ; confirmer l'absence de secrets et de documents intégraux. Pour chaque catégorie, vérifier la suppression des données ayant dépassé la durée de conservation définie et le maintien des seules données couvertes par une exception justifiée.

Fonctions BF-08, BF-11, BF-12 Scénarios d'abus MU-05, MU-08

Distribution et marquage

SR-11 Vérification d'intégrité des versions originales

Critique · I

Exigence. À chaque publication d'une version, DocTrace doit calculer et enregistrer SHA-256 sur les octets du document original avant chiffrement. Avant de préparer une copie à distribuer, il doit recalculer SHA-256 sur les octets déchiffrés et comparer la valeur à celle enregistrée pour cette version. Toute divergence doit interdire la distribution et produire un événement d'audit.

Justification. Détecter les altérations non cohérentes avec la version publiée, avant insertion d'un marquage.

Critère de vérification. Publier un document, altérer le chiffré ou remplacer le document sauvegardé et tenter une distribution ; vérifier le refus et l'événement. Vérifier une version intacte comme cas positif. L'empreinte seule ne garantit pas l'authenticité d'une référence modifiable par un même attaquant.

Fonctions BF-05, BF-08, BF-10 Scénarios d'abus MU-04

SR-12 Watermark des copies PDF par distribution

Critique · I

Exigence. Chaque PDF destiné à être distribué doit comporter sur chaque page une marque visible associant la copie à son destinataire et à son identifiant de distribution, ainsi qu'une marque discrète contenant cet identifiant. La marque discrète doit être répétée sur au moins trois emplacements indépendants lorsque la mise en page le permet, conformément à la politique de marquage. Le service doit vérifier sur le PDF final la présence des marques prescrites ; un PDF dont les marques requises manquent ne peut pas être émis.

Justification. Permettre une distinction des copies distribuées et une recherche ultérieure d'identifiant.

Critère de vérification. Générer des PDF d'une et plusieurs pages pour deux destinataires ; contrôler marques et identifiants sur chaque page, y compris la discrète, puis provoquer un échec d'insertion ; aucune copie sans marques requises ne doit être émise.

Fonctions BF-08 Scénarios d'abus MU-04, MU-07

SR-13 Stéganographie vérifiée dans les images compatibles

Critique · I/C

Exigence. Pour chaque image PNG embarquée et éligible au procédé défini dans le périmètre fonctionnel (capacité contrôlée, dimensions au moins 128 × 128 pixels), le moteur doit insérer dans les pixels une charge contenant l'identifiant de distribution, chiffrée et authentifiée avec AES-256-GCM, puis réussir à l'extraire du document final. L'absence d'image éligible doit produire le statut « non applicable » sans constituer un échec. Si une image identifiée comme éligible ne peut pas être marquée ou relue authentiquement, la copie ne doit pas être émise.

Justification. Assurer une trace cachée authentifiable lorsque le support réellement disponible le permet, sans la confondre avec une métadonnée.

Critère de vérification. Tester une image PNG éligible, une image de taille insuffisante, un PDF sans PNG éligible et un identifiant altéré ; vérifier respectivement extraction authentifiée, statut non applicable, statut non applicable et impossibilité d'attribution. Simuler un échec de marquage sur une image éligible : émission refusée.

Fonctions BF-08, BF-09 Scénarios d'abus MU-04, MU-07

SR-15 Contrôles préalables, unicité et empreinte de distribution

Critique · I

Exigence. Chaque opération de distribution doit recevoir un identifiant unique. Avant de commencer à transmettre une copie, le middleware doit avoir validé l'autorisation d'accès, l'intégrité de l'original, l'application et la vérification des marques obligatoires (ou leur non-applicabilité selon le support de marquage), le SHA-256 exact du fichier final et la création d'un enregistrement de distribution authentifié associant document, version, destinataire, horodatage, empreinte et état. L'échec de l'un de ces contrôles doit interdire toute émission documentaire et produire un état « échec ». L'état « émise » signifie uniquement que le serveur a commencé le transfert autorisé, sans attester la réception complète par le navigateur.

Justification. Garantir l'unicité, la traçabilité et la conformité de chaque copie émise, sans diffuser un document dont les contrôles obligatoires ont échoué.

Critère de vérification. Effectuer deux distributions de la même version et vérifier la différence des identifiants. Recalculer l'empreinte sur la copie obtenue après une transmission complète. Provoquer successivement un refus d'autorisation, une altération de l'original, un échec de marquage, un défaut d'empreinte et un échec d'enregistrement : aucun octet documentaire ne doit être émis et l'état ne doit pas être « émise ».

Fonctions BF-08, BF-10 Scénarios d'abus MU-04, MU-07

SR-16 Authenticité cryptographique des preuves de distribution

Critique · I

Exigence. Avant l'utilisation d'un enregistrement de distribution comme preuve technique, DocTrace doit vérifier un code d'authentification HMAC-SHA-256 calculé sur une sérialisation canonique des champs obligatoires (distributionId, version, destinataire, date, empreinte, état). La clé HMAC doit être distincte de la clé de chiffrement des documents et inaccessible aux utilisateurs. Tout enregistrement dont l'authentification échoue doit être rejeté pour l'attribution et donner lieu à une alerte d'intégrité.

Justification. Empêcher la modification silencieuse des associations entre destinataires, copies et événements de remise.

Critère de vérification. Modifier séparément chaque champ authentifié, supprimer le code HMAC ou vérifier avec une autre clé : la vérification doit échouer et la preuve doit être exclue de l'attribution. Une preuve non modifiée avec un HMAC valide doit être acceptée.

Fonctions BF-08, BF-11, BF-12 Scénarios d'abus MU-04, MU-05, MU-07

SR-17 Qualification prudente des résultats d'investigation

Critique · I

Exigence. L'investigation doit classer chaque résultat dans l'un des états suivants : « correspondance exacte avec une copie enregistrée et authentifiée », « marque authentifiée et identifiant retrouvé » ou « preuve insuffisante ». Le rapport doit mentionner la méthode, le niveau de confiance associé et toute impossibilité de vérification. L'identification d'une distribution ne doit jamais être présentée comme preuve certaine de l'auteur humain de la fuite.

Justification. Éviter une attribution personnelle erronée et rendre les limites des indices lisibles dans les rapports.

Critère de vérification. Tester une copie identique, une copie transformée avec marque encore vérifiable, une charge forgée et un document sans marque ; vérifier le classement de chaque fichier dans l'un des trois états définis ainsi que les réserves sur l'attribution humaine.

Fonctions BF-11 Scénarios d'abus MU-07

Audit et traçabilité

SR-18 Journalisation contrôlée des opérations sensibles

Élevée · I

Exigence. Les changements de rôle et d'ACL, publications, distributions, refus d'accès, échecs de traitement ou de marquage et opérations d'investigation doivent produire un événement horodaté avec type, identifiant d'acteur, identifiant d'objet, résultat et identifiant de corrélation. Les interfaces applicatives ne doivent fournir aucune opération de modification ou de suppression de ces événements. L'accès à leur consultation doit respecter SR-03 et leur contenu SR-10.

Justification. Permettre la reconstitution des opérations critiques tout en limitant les modifications via l'application.

Critère de vérification. Exécuter les opérations sensibles autorisées et refusées, puis vérifier les champs et événements attendus. Tenter la modification ou la suppression des traces via chaque rôle applicatif : les API doivent refuser toutes ces opérations. Vérifier l'absence de secrets dans les événements.

Fonctions BF-02, BF-04, BF-06, BF-08, BF-11, BF-12 Scénarios d'abus MU-05

Interface, services et disponibilité

SR-20 Validation des API et prévention des injections

Élevée · C/I

Exigence. Le middleware doit vérifier pour chaque entrée API le type, le format, la taille, les valeurs autorisées et les règles métier applicables, avant tout accès aux données. Toute interaction SQL doit employer des requêtes paramétrées. L'interface doit encoder les données non fiables selon le contexte d'affichage ; elle ne doit pas injecter directement du HTML non nettoyé. Les réponses d'erreur adressées au client ne doivent divulguer ni pile d'exécution, ni secret, ni chaîne de connexion. Une CSP explicite doit limiter les sources de scripts aux sources approuvées.

Justification. Prévenir les injections, l'exécution de scripts malveillants dans la SPA et les fuites d'informations techniques.

Critère de vérification. Injecter des chaînes SQL et HTML/JavaScript dans recherches, métadonnées, paramètres de pagination et identifiants ; vérifier refus ou traitement comme données, absence d'exécution script, CSP active et réponses sans détails internes.

Fonctions BF-03, BF-06, BF-07, BF-13 Scénarios d'abus MU-01, MU-08

SR-21 Non-mise-en-cache des données sensibles dans la PWA

Élevée · C

Exigence. Le service worker doit limiter Cache Storage aux ressources statiques non sensibles de la SPA. Aucun document, réponse API confidentielle ou jeton ne doit être persisté par l'application dans Cache Storage, IndexedDB, localStorage ou sessionStorage. Les réponses documentaires et API sensibles doivent porter la directive HTTP Cache-Control: no-store et être exclues des stratégies de cache de la PWA.

Justification. Empêcher que l'application conserve silencieusement du contenu confidentiel sur un poste partagé.

Critère de vérification. Télécharger une copie, consulter les métadonnées, se déconnecter puis inspecter Cache Storage et les autres stockages de l'origine, en ligne et hors connexion ; aucune réponse sensible mise en cache par l'application ne doit être présente. Vérifier les en-têtes HTTP no-store.

Fonctions BF-08, BF-13 Scénarios d'abus MU-08

SR-22 Protection des origines et des services exposés

Élevée · C/I

Exigence. L'API publique doit configurer CORS avec une liste explicite des origines autorisées ; l'origine non reconnue ne doit pas recevoir une autorisation CORS. Si l'API accepte des cookies comme preuve d'authentification, les opérations modifiant l'état doivent appliquer une protection CSRF vérifiable ; avec des jetons Bearer explicites et sans authentification par cookie, aucun cookie ne doit accorder d'accès API. Les consoles WildFly, bases de données et interfaces internes de gestion ne doivent pas être directement accessibles depuis la zone Internet.

Justification. Réduire les accès intersites abusifs et la surface d'attaque des composants d'administration.

Critère de vérification. Tester une origine autorisée et une non autorisée ; en cas d'authentification par cookie, tester une requête intersite de modification d'état sans jeton CSRF valide ; depuis l'extérieur, tester l'inaccessibilité des ports et consoles internes.

Fonctions BF-01, BF-02, BF-13 Scénarios d'abus MU-06, MU-08

SR-23 Quotas et disponibilité des traitements

Critique · A/I

Exigence. Les opérations d'import, de distribution et d'investigation doivent être soumises à des quotas et limites de débit par acteur. Les tâches coûteuses doivent passer par une file d'attente de capacité bornée et respecter un nombre maximal d'exécutions simultanées. Une requête excédant l'un de ces plafonds doit être refusée sans lancement de tâche supplémentaire. Les tâches interrompues lors du traitement des fichiers, conformément à SR-07, doivent libérer leurs ressources et leurs fichiers temporaires.

Justification. Préserver le service en cas de requêtes répétitives ou de charge simultanée et maintenir un comportement prévisible lors des refus.

Critère de vérification. Effectuer des requêtes dépassant successivement les quotas, le débit autorisé, le nombre maximal de tâches simultanées et la capacité de file configurés ; contrôler les refus (HTTP 429 pour les quotas et le débit), l'absence de tâches supplémentaires et la reprise de capacité après interruption. Les limites de décodage et de durée propres à un fichier sont testées au titre de SR-07.

Fonctions BF-04, BF-08, BF-11 Scénarios d'abus MU-03, MU-04

SR-24 Sauvegarde et restauration vérifiée

Élevée · A/I

Exigence. DocTrace doit disposer de sauvegardes chiffrées accessibles uniquement aux comptes de restauration habilités et conservées séparément du stockage actif. Elles doivent permettre une restauration cohérente des originaux chiffrés, des métadonnées et ACL, des enregistrements de distribution, des journaux et des clés nécessaires au déchiffrement. Une procédure de restauration doit vérifier la cohérence des références, les empreintes et la possibilité d'un déchiffrement autorisé.

Justification. Éviter qu'une panne ou une restauration incomplète rende les documents ou les historiques de distribution inutilisables.

Critère de vérification. Restaurer une sauvegarde en environnement isolé, vérifier la correspondance des documents, versions, ACL et distributions, recalculer les empreintes et déchiffrer un document avec une clé restaurée de manière autorisée. Tout ensemble incohérent doit être signalé et non réutilisé en production.

Fonctions BF-05, BF-12 Scénarios d'abus MU-05

PARTIE III

Évaluation des risques

Cotation des scénarios · contrôles d'atténuation · risques résiduels estimés

11 Méthode et échelles de cotation

La démarche retient une matrice semi-quantitative 4 × 4. Le score est calculé par multiplication de la vraisemblance V et de l'impact I : R = V × I. La même grille est employée pour les niveaux bruts et résiduels.

Niveau	Vraisemblance (V)	Impact (I)
1	Improbable : prérequis et compétences exceptionnels.	Mineur : perturbation limitée sans fuite documentaire.
2	Possible : attaquant motivé, moyens ordinaires.	Modéré : altération ou indisponibilité locale.
3	Probable : scénario accessible à un acteur courant.	Majeur : fuite d'un document, marquage contourné ou trace altérée.
4	Très probable : attaque facilement automatisable.	Critique : fuite massive, compromission des clés ou preuves gravement falsifiées.

Score R	Niveau	Traitement
1 à 3	Faible	Surveillance et maintien des contrôles.
4 à 8	Moyen	Mesures d'atténuation ciblées.
9 à 12	Élevé	Traitement prioritaire avant mise en service.
15 à 16	Critique	Condition bloquante pour la mise en service.

12 Registre détaillé des risques

R-01 — Usurpation d'accès et contournement des ACL

MU-01

Scénario de menace. Un utilisateur READER modifie l'identifiant d'un document dans une requête REST afin de lire une ressource non autorisée.

Risque brut	Risque résiduel estimé
V=3 · I=4 · **12/16 — Élevé**	V=1 · I=3 · **3/16 — Faible**

Mesures de réduction. SR-03 et SR-04 : contrôles RBAC, ACL, habilitation et autorisation par objet côté serveur ; refus sans fuite de métadonnées.

Exposition résiduelle. L'exposition demeure possible en cas d'erreur de contrôle d'accès dans une route ou une recherche.

R-02 — Import malveillant et exploitation d'un parseur

MU-02

Scénario de menace. Un PUBLISHER compromis téléverse un fichier déguisé ou malformé pour exploiter PDFBox, ImageIO ou le pipeline d'analyse.

Risque brut	Risque résiduel estimé
V=3 · I=4 · **12/16 — Élevé**	V=1 · I=3 · **3/16 — Faible**

Mesures de réduction. SR-06 et SR-07 : listes d'admission, structure réelle, antivirus, limites de traitement et rejet des contenus actifs non autorisés.

Exposition résiduelle. Une vulnérabilité inconnue du moteur de traitement demeure possible malgré les contrôles d'admission.

R-03 — Épuisement des ressources de marquage

MU-03

Scénario de menace. Des demandes concurrentes d'import, de marquage et d'investigation saturent les ressources du middleware.

Risque brut	Risque résiduel estimé
V=3 · I=3 · **9/16 — Élevé**	V=1 · I=2 · **2/16 — Faible**

Mesures de réduction. SR-23 : quotas par acteur, débit limité et files bornées ; SR-07 : contrôle des ressources des tâches de traitement.

Exposition résiduelle. Des surcharges ponctuelles restent possibles ; la protection contre les attaques DDoS volumétriques n'entre pas dans le périmètre.

R-04 — Contournement du marquage d'une copie

MU-04

Scénario de menace. Un attaquant tente d'obtenir une copie non marquée, partiellement marquée ou non associée à un enregistrement de distribution.

Risque brut	Risque résiduel estimé
V=2 · I=4 · **8/16 — Moyen**	V=1 · I=3 · **3/16 — Faible**

Mesures de réduction. SR-11, SR-12, SR-13 et SR-15 : contrôle de l'original, marques vérifiées, enregistrement authentifié et interdiction d'émission en cas d'échec.

Exposition résiduelle. Une transformation destructrice ultérieure peut rendre les marques inexploitables après remise du document.

R-05 — Altération de journaux ou de preuves de distribution

MU-05

Scénario de menace. Un acteur disposant d'accès privilégiés modifie des événements d'audit ou des enregistrements afin de dissimuler une distribution.

Risque brut	Risque résiduel estimé
V=2 · I=4 · **8/16 — Moyen**	V=1 · I=2 · **2/16 — Faible**

Mesures de réduction. SR-03 et SR-18 : séparation des fonctions et journal non modifiable via API ; SR-16 : HMAC des enregistrements de distribution. Le CDC prévoit un journal chaîné pour détecter des altérations locales.

Exposition résiduelle. Le contrôle cryptographique des distributions ne protège pas à lui seul l'intégralité du journal ; une réécriture complète par un administrateur privilégié reste un scénario à considérer.

R-06 — Réutilisation de jetons et vol de session

MU-06 / MU-08

Scénario de menace. Un attaquant tente de réutiliser un jeton, exploite une session de navigateur ou récupère du contenu sensible depuis le cache sur un poste partagé.

Risque brut	Risque résiduel estimé
V=3 · I=3 · **9/16 — Élevé**	V=1 · I=2 · **2/16 — Faible**

Mesures de réduction. SR-01 et SR-02 : OIDC, validation des jetons, MFA, PKCE et expiration ; SR-21 et SR-22 : protection du cache et de l'exposition des services.

Exposition résiduelle. Un terminal déjà compromis reste un risque important, notamment pendant une session légitime.

R-07 — Falsification de marque et attribution erronée

MU-07

Scénario de menace. Un destinataire modifie ou forge une marque afin de faire associer une copie suspecte à une autre distribution.

Risque brut	Risque résiduel estimé
V=2 · I=4 · **8/16 — Moyen**	V=1 · I=2 · **2/16 — Faible**

Mesures de réduction. SR-13 : charge chiffrée et authentifiée ; SR-16 : authenticité des enregistrements ; SR-17 : présentation prudente des résultats d'investigation.

Exposition résiduelle. L'identification d'une copie ne permet pas, à elle seule, d'identifier avec certitude l'auteur humain de la divulgation.

13 Cartographie des risques et limites résiduelles

Évaluation brute

V \ I	1	2	3	4
4	·	·	·	·
3	·	·	R-03, R-06	R-01, R-02
2	·	·	·	R-04, R-05, R-07
1	·	·	·	·

Évaluation résiduelle estimée

V \ I	1	2	3	4
4	·	·	·	·
3	·	·	·	·
2	·	·	·	·
1	·	R-03, R-05, R-06, R-07	R-01, R-02, R-04	·

Les valeurs résiduelles indiquent l'exposition attendue après application des mesures décrites. Elles ne représentent pas une mesure de performance réalisée sur une application déployée. Leur confirmation repose sur la vérification technique des contrôles.

13.1 Limites et exposition persistante

- Capture d'écran, photographie externe ou ressaisie : aucun mécanisme serveur ne peut empêcher totalement la reproduction après accès autorisé.
- Transformations d'image destructrices : le rognage, la recompression ou le redimensionnement peuvent effacer les marques LSB ; une absence de marque ne permet pas de conclure à une absence de fuite.
- Attribution humaine : même une correspondance exacte à une copie enregistrée démontre une association technique avec une distribution, pas l'identité certaine du divulgateur.
- Opérateur privilégié et journaux : la restriction des API d'audit ne suffit pas à détecter une réécriture complète des journaux en base par un acteur disposant de privilèges étendus.
- Indisponibilité réseau volumétrique : l'atténuation traitée relève principalement des ressources applicatives et non de la protection anti-DDoS au niveau de l'accès réseau.

14 Glossaire et références

Terme	Définition
CDC	Cahier des charges : besoins métier, périmètre et architecture du système.
BF	Identifiant d'un besoin fonctionnel.
MU / Misuse Case	Scénario d'abus décrivant une exploitation adverse d'une fonctionnalité.
SR	Exigence de sécurité du produit avec justification et test d'acceptation.
SRE	Security Requirements Engineering : ingénierie des exigences de sécurité.
RBAC / ACL	Contrôle d'accès par rôles / liste d'autorisations sur une ressource.
OIDC / PKCE	OpenID Connect / Proof Key for Code Exchange.
LSB	Least Significant Bit : insertion de données dans les bits de poids faible des pixels.
Fingerprinting	Calcul de SHA-256 pour identifier un fichier octet pour octet.

Terme	Définition
Watermarking	Marquage visible ou discret d'un document.
DEK / KEK	Clé de chiffrement des données / clé protégeant une autre clé.
Fail-closed	Refus de l'opération lorsque le contrôle nécessaire ne peut pas être validé.
BOLA / IDOR	Défaut d'autorisation au niveau d'un objet accessible par identifiant.
HMAC / AES-GCM	Authentification par MAC fondée sur clé partagée / chiffrement authentifié.
PSNR	Peak Signal-to-Noise Ratio, mesure de qualité de l'image transformée.
CIA	Confidentialité, intégrité et disponibilité.

Références techniques et méthodologiques. Spécifications Jakarta EE 11 ; documentation WildFly et Keycloak ; Apache PDFBox ; OWASP ASVS et Cheat Sheet Series ; NIST SP 800-63B ; RFC 6238 (TOTP) ; RFC 5869 (HKDF) ; NIST SP 800-38D (AES-GCM) ; UMLsec et OMG UML 2.5 ; méthode SQUARE.